

Étudiant : ALIAWY MFAM SAKER RICHLAND

RAPPORT DU TP 4.2 – DETECTION D’ATTAQUES AVEC UN IDS/IPS (SURICATA SUR PFSENSE)

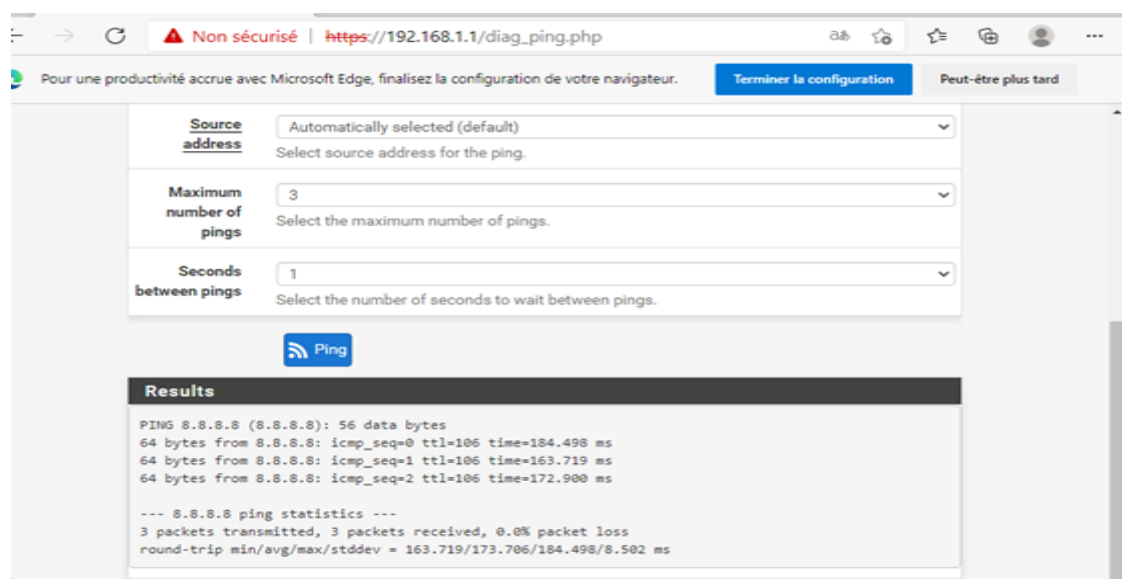
Architecture :

- pfSense (192.168.1.1) avec Suricata
- LAN : Ubuntu (192.168.1.10), Windows (192.168.1.20)
- Attaquant : Kali (sur le réseau WAN)

1. INTRODUCTION

Après avoir segmenté le réseau et contrôlé les flux avec pfSense, nous ajoutons maintenant une couche d’inspection profonde des paquets. Suricata, installé sur pfSense, fonctionne comme un IDS (Intrusion Detection System) puis en IPS (Intrusion Prevention System). Il utilise des signatures (règles) pour détecter des comportements malveillants (scans, brute force, exploits). Ce TP valide que les attaques précédentes (Nmap, Metasploit) sont détectables.

2. ÉTAPE 1 – INSTALLATION DE SURICATA SUR PFSENSE

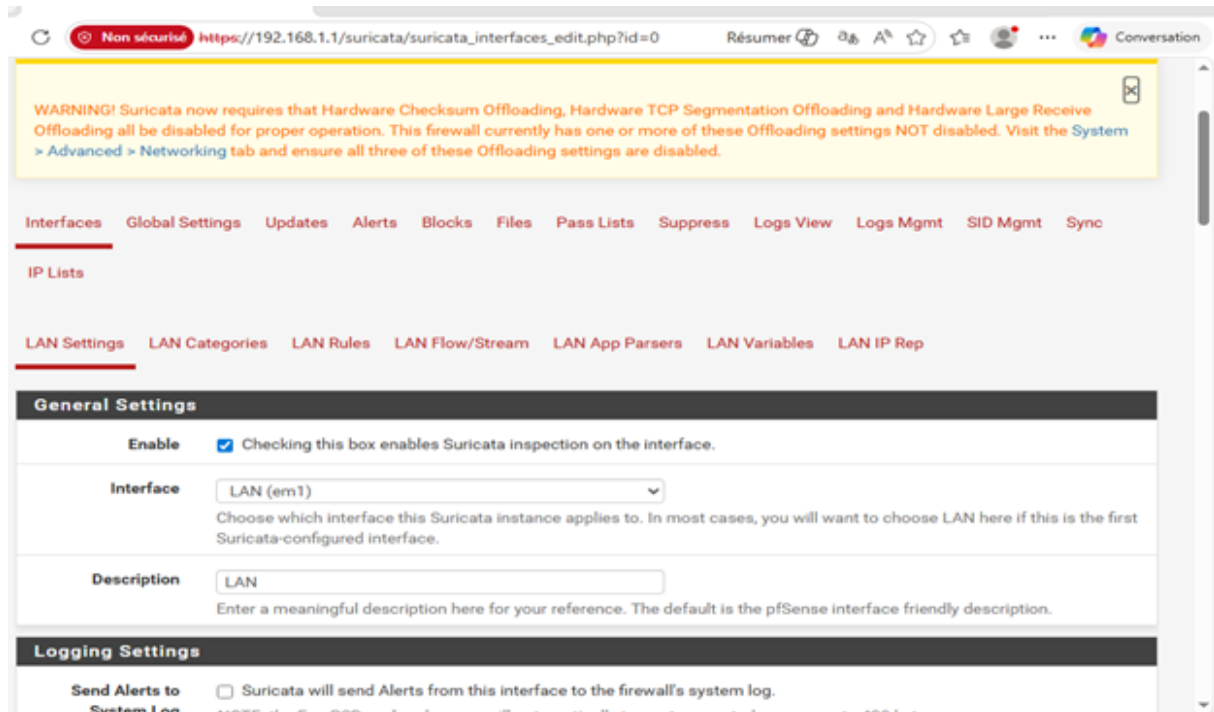




Accès à System > Package Manager > Available Packages, recherche du paquet Suricata et clic sur Install

Interprétation : L'installation ajoute le service Suricata à pfSense. Une fois installé, il apparaîtra dans le menu Services.

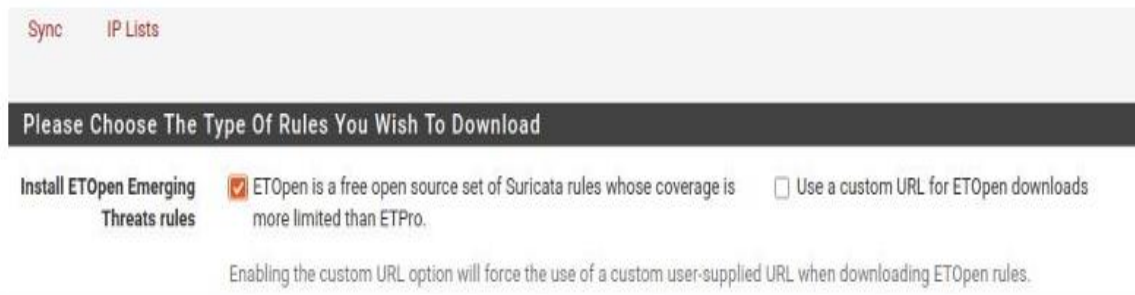
3. ÉTAPE 2 – ACTIVATION DE SURICATA SUR L'INTERFACE LAN



Services > Suricata → bouton Add → sélection de l'interface LAN (ex: em1) → Save

Interprétation : On surveille le trafic LAN car c'est là que circulent les échanges entre les machines internes et l'extérieur. Les attaques depuis Kali (WAN) vers Ubuntu/Windows passeront par cette interface.

4. ÉTAPE 3 – ACTIVATION DES REGLES DE DETECTION



Onglet Global Settings – case Enable ET Open Rules cochée

Interprétation : Les règles ET Open (Emerging Threats Open) sont une base de signatures communautaires. Elles permettent de reconnaître des milliers d'attaques (scans, exploits, malwares). Sans ces signatures, Suricata ne pourrait rien détecter.

6. ÉTAPE 5 – GENERATION D'UNE ATTAQUE (SCAN NMAP DEPUIS KALI)

Depuis Kali, lancer un scan SYN vers Ubuntu : `nmap -sS 192.168.1.10`

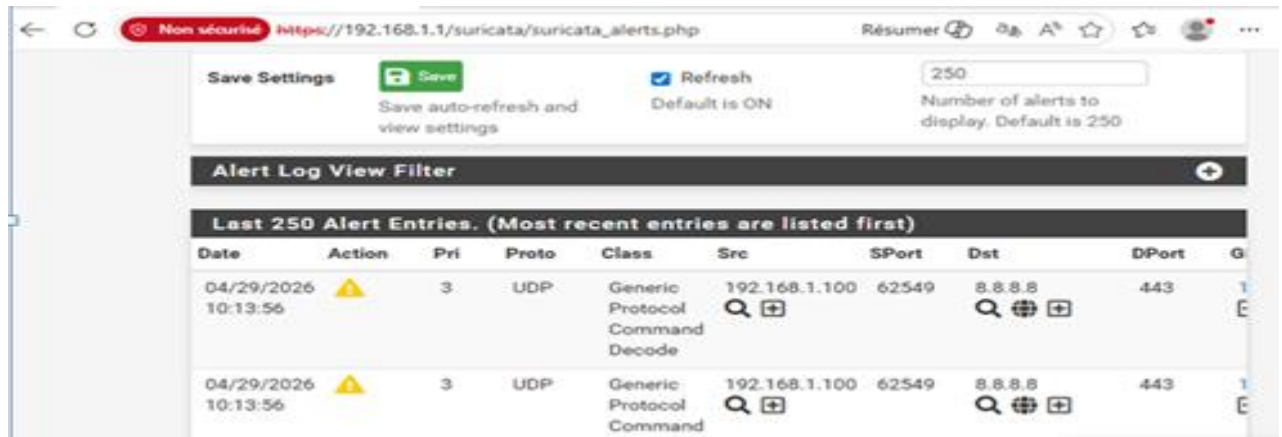
```
$ nmap -sS 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 10:09 +0200
Nmap scan report for 192.168.1.10
Host is up (0.0025s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:B9:97:BF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.42 seconds
```

Terminal Kali affichant le scan en cours

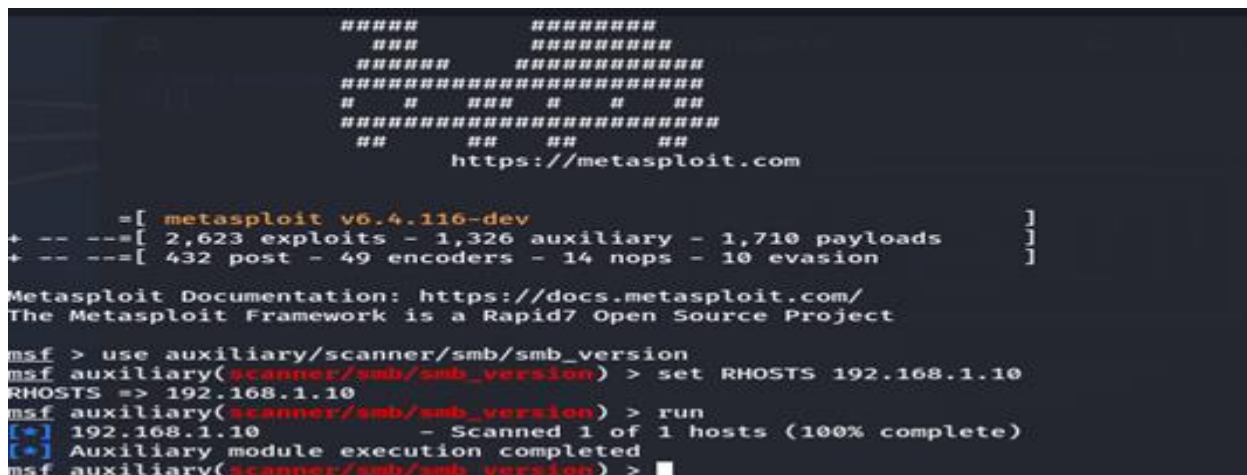
7. ÉTAPE 6 – ANALYSE DES ALERTES SURICATA

Suricata a identifié le scan grâce à la signature correspondant à l'outil Nmap. Chaque alerte contient un message descriptif, la source, la destination, le protocole. Cela prouve que le système détecte l'attaque, même si elle n'est pas bloquée (mode IDS).



8. ÉTAPE 7 – SIMULATION D'UNE ATTAQUE PLUS AVANCÉE (METASPLOIT)

Depuis Kali, lancer Metasploit et exécuter une exploitation (ex : use exploit/windows/smb/ms17_010_eternalblue vers Windows).



Console Metasploit avec la tentative d'exploit

Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GLC
04/29/2026 12:06:54	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.100	59528	8.8.4.4	443	1:1
04/29/2026 12:06:54	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.100	59528	8.8.4.4	443	1:1
04/29/2026 12:06:54	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.100	59528	8.8.4.4	443	1:1

Nouvelles alertes Suricata (exemple : ET EXPLOIT ETERNALBLUE)

Interprétation : Suricata détecte ici un exploit réel, pas seulement un scan. La signature reconnaît le pattern réseau de l'attaque EternalBlue. Ces alertes sont souvent plus critiques (niveau high). L'IDS permet de repérer des tentatives d'intrusion avant qu'elles ne réussissent.

9. ÉTAPE 8 – PASSAGE EN MODE IPS (BLOCAGE)

9.1 CONFIGURATION DU MODE BLOCAGE

Alert and Block Settings

Block Offenders ☒ Checking this option will automatically block hosts that generate a Suricata alert.

IPS Mode Legacy Mode
 Select blocking mode operation. Legacy Mode inspects copies of packets while Inline Mode inserts the Suricata inspection engine into the network stack between the NIC and the OS. Default is Legacy Mode.
 Legacy Mode uses the PCAP engine to generate copies of packets for inspection as they traverse the interface. Some "leakage" of packets will occur before Suricata can determine if the traffic matches a rule and should be blocked. Inline mode instead intercepts and inspects packets before they are handed off to the host network stack for further processing. Packets matching DROP rules are simply discarded (dropped) and not passed to the host network stack. No leakage of packets occurs with Inline Mode. WARNING: Inline Mode only works with NIC drivers which properly support Netmap! Supported drivers include: bnxt, cc, cxgbe, cxl, em, ena, ice, igb, igc, ix, ixgbe, ixl, lem, re, vmx, vtnet. If problems are experienced with Inline Mode, switch to Legacy Mode instead.

Kill States ☒ Checking this option will kill firewall states for the blocked IP. Default is Checked.

Which IP to Block BOTH
 Select which IP extracted from the packet you wish to block. Choosing BOTH is suggested, and it is the default value.

Block On DROP Only ☐ Checking this option will insert blocks only when rule signatures having the DROP action are triggered. When not checked, any rule action (ALERT or DROP) will generate a block of the offending host. Default is Not Checked.

IP Pass List default [View List](#)
 Choose the Pass List you want this interface to use. Addresses in a Pass List are never blocked. Select "none" to prevent use of a Pass List.
 The default Pass List adds Gateways, DNS servers, locally-attached networks, the WAN IP, VPNs and VIPs. Create a Pass List with an alias to customize whitelisted IP addresses. This option will only be used when block offenders is on. Choosing "none" will disable Pass List generation.

Enable Passlist Debugging Log ☐ Checking this option will enable detailed Passlist operations logging to file /var/log/suricata/suricata_em144392/passlist_debug.log. Default is Not Checked.

Performance and Detection Engine Settings

Modification de l'interface LAN – cocher Block offenders (ou IPS mode) → Save → Apply Changes

Interprétation : En mode IPS, Suricata peut bloquer automatiquement l'IP source de l'attaque (ou les paquets malveillants) en plus de générer des alertes.

10. SYNTHESE – IDS VS IPS

Mode Fonction Exemple

IDS Détecte et alerte Suricata signale le scan, mais le scan réussit.

IPS Détecte, alerte et bloque Suricata coupe la communication de l'attaquant.

Notre TP : nous sommes passés du mode IDS (détection) au mode IPS (prévention).

11. INTERET DES SIGNATURES

- Une signature est un motif spécifique (ex : séquence de flags TCP, contenu de payload, user-agent) qui caractérise une attaque connue.
- Avantages : détection fiable, faible taux de faux positifs si bien maintenues.
- Limites : ne détecte pas les attaques zero-day (inconnues) ; nécessite des mises à jour régulières.

13. CONCLUSION

Ce TP a démontré l'importance d'un IDS/IPS dans une architecture sécurisée.

- Le pare-feu pfSense contrôle les flux (qui communique avec quoi).
- Suricata analyse le contenu des paquets et détecte des comportements malveillants (scans, exploits).
- En mode IPS, il peut bloquer activement les attaques.

Les attaques que nous avons simulées (Nmap, Metasploit) sont bien détectées, validant l'efficacité des signatures.

COMPETENCES ACQUISES :

- Installation et configuration de Suricata sur pfSense.
- Activation de règles de signatures.
- Interprétation des alertes (niveau de sévérité, description).
- Compréhension IDS vs IPS.
- Utilisation avancée du seuillage et des types de règles.

Perspectives :

- Affiner les règles pour réduire les faux positifs.
- Coupler Suricata avec un SIEM (Wazuh) pour centraliser les alertes.
- Ajouter des règles personnalisées pour des menaces spécifiques à l'entreprise.